AI Governance Process and Risk Management Review

Decision rights, risk inheritance and solution-level assurance – Potential findings and Proposals

Jori Eskolin | 30 October 2026

Executive Summary

The existing AI Governance materials provide a useful governance process structure and practical guidance for using Saidot. They describe the AI lifecycle, component linking, risk inheritance, risk ownership, inherent and residual assessment, treatment options and review tasks. The principal weakness is that the operation of the tool is described more precisely than the formation of a sound governance decision.

The documentation does not yet provide a coherent and demonstrable method for determining who has decision authority, how risks are inherited from the correct service and contractual profile, how solution-specific risks are made complete, and what evidence is required before residual risk is reduced and accepted.

Key Findings

The AI governance materials contain genuine contradictions and material methodological gaps. Both the risk assessment guidance and the end-to-end governance process remain unclear and insufficiently defined. The central problem is not a missing software feature. It is the lack of a coherent and operational solution risk assessment and assurance method, with explicit decision rights, connecting intended use, outputs, decisions and consequences to the process, tool configuration, qualification checklist, control evidence, residual risk acceptance and final approval.

Key conclusions

- AI Board decision rights are inconsistent. The RASCI matrix assigns accountability to the AI System Owner and no A role to the AI Board, while several diagrams and instructions require the AI Board to approve risk posture, deployment and retirement.
- Risk inheritance is described at the level of technical links, but not sufficiently at the level of assessment logic. The guidance does not ensure that risks originate from the correct product, service tier, model version, contract, configuration and operating model.
- A risk treatment workflow exists, including accept, mitigate and avoid. However, the materials do not adequately define solution-specific risk scenarios, completeness criteria, deduplication, control effectiveness evidence or authorised residual risk acceptance.
- AI Act classification, business importance, component risk levels, individual residual risks and overall risk posture are not connected through an explicit decision method. A low regulatory classification or an acceptable tool status must not be interpreted as proof of solution-level assurance.

Essential changes

- Unify AI Board and AI System Owner decision rights and define risk acceptance authority and escalation thresholds.
- Bind inherited risks to the actual service model, contract, configuration and solution architecture.
- Require control effectiveness evidence, authorised residual risk acceptance and explicit rules for overall solution risk decisions.

Scope note: This review assesses the supplied documentation and the working method visible in the examples. It does not claim to define the maximum technical capability of the Saidot product.

Contents

Executive Summary **1**
Key conclusions 1
Essential changes 1
1. Findings **2**
1.1 AI Board decision rights are internally inconsistent 2
1.2 The AI Board mandate and escalation threshold are unclear 3
1.3 Risk inheritance is described technically, not methodologically 3
1.4 The treatment workflow exists, but its quality criteria are incomplete 3
1.5 Solution-level completeness is not demonstrated 4
1.6 Control implementation and control effectiveness are not separated 4
1.7 Overall solution risk and risk posture are not integrated 4
1.8 The checklist does not fully align with the intended method 4
2. Recommended Changes **4**
2.1 Essential change 1: Unify decision rights and risk acceptance 5
2.2 Essential change 2: Bind risk inheritance to the actual service profile 5
2.3 Essential change 3: Require evidence and define overall risk decisions 5
2.4 Supporting change: Adopt a solution risk workflow 6
2.5 Supporting change: Strengthen lifecycle gate deliverables 6
2.6 Supporting change: Align the checklist and implementation guidance 7
2.7 Implementation priority and expected outcome 7

1. Findings

The findings distinguish between content that is present in the materials and the quality rules needed to make that content reliable. This distinction matters because the process includes many appropriate steps, but their inputs, evidence and decision authority remain underspecified.

1.1 AI Board decision rights are internally inconsistent

The process RASCI matrix assigns the AI System Owner an A role throughout the lifecycle. The AI Board has an R role in three phases: AI System Qualification and Registration, Deployment and Retire AI System. It has no A role in the matrix.

Other parts of the same material nevertheless describe the AI Board as the body that makes binding approval decisions.

Source	Role or decision assigned to the AI Board
Process role description, page 6	Determines whether the AI system is qualified to proceed to implementation.
Process flow, page 7	Validates the system, approves progression to design and development, accepts the risk action plan, evaluates residual risks, approves deployment and approves retirement.
Guideline, pages 19, 23, 24, 29 and 86	Approves risk posture, completes and approves risks, approves deployment and approves the system after re-evaluation.
AI System Qualification Checklist	Records Approved, Approved with conditions, Rework required or Rejected as the Board decision.

These descriptions cannot be reconciled unambiguously through the R role alone. If the AI Board makes the binding decision, its decision accountability must be explicit. If it only prepares or recommends a decision, the word approve should not be used without identifying the final decision maker.

1.2 The AI Board mandate and escalation threshold are unclear

Guideline page 28 limits the stated AI Board purpose to solutions classified as High or Unacceptable risk. Other sections describe AI Board approvals without an equivalent threshold. The documentation therefore leaves open whether every system requires Board approval or only systems exceeding a defined risk level.

The statement that the AI Board may approve implementation of an Unacceptable risk solution also requires correction. If Unacceptable means that the organisation's acceptance threshold has been exceeded, the available decisions should be to avoid or redesign the use, reduce the risk before reassessment, or follow a separately authorised exception process. An unacceptable risk should not become acceptable merely through the same approval.

1.3 Risk inheritance is described technically, not methodologically

The guideline does describe inheritance. Pages 18, 38, 45, 62, 63, 70 and 71 explain that risks can arise from linked agents, models, products and datasets, while context can generate additional risk recommendations. The separation of System, Product, Model, Agent and Platform is a useful foundation.

The missing element is a controlled method for selecting and validating the risk profile. The process does not adequately require confirmation of:

- the exact commercial product and service tier, including consumer, enterprise contracted, self-hosted or hybrid operation
- the model and product version, relevant safety configuration and actual tenant settings
- the contract and service description used as the assessment basis, including their version and applicability
- data use, retention, region, subprocessors, logging, change notification, support and exit arrangements
- additional risks created by in-house operation, internal maintenance, model provenance, infrastructure and security responsibilities.

Inheritance is therefore defined at the level of links, but not sufficiently at the level of risk profile selection and content. A generic model card must not be treated as an enterprise service assessment without confirming its service and contractual scope.

1.4 The treatment workflow exists, but its quality criteria are incomplete

Guideline pages 73 to 78 describe a sensible sequence: document the risk, evaluate inherent and marginal risk, select a treatment strategy, define mitigations, assess residual risk and approve risk posture. The checklist also includes accept, mitigate and avoid. It would therefore be inaccurate to say that treatment is entirely absent.

The difficulty is that the instructions do not define what constitutes a good assessment. Generic risk names and descriptions can remain disconnected from the actual solution, and a residual score can be entered without a clear requirement for evidence that the control is implemented and effective.

Gap	Why it matters
Solution-specific scenario	The same generic risk can have different causes, affected parties, likelihood and impact in different architectures and business processes.
Completeness criteria	Inherited and recommended risks do not prove that all material solution risks have been identified.
Deduplication and lineage	Deleting duplicates can remove traceability, while independent treatment of repeated risks can create unnecessary work and inconsistent controls.
Effectiveness evidence	A planned or in-progress mitigation does not justify the same residual risk reduction as a tested and operating control.

Gap	Why it matters
Acceptance authority	The availability of accept, mitigate and avoid does not establish who may accept which residual risk.

1.5 Solution-level completeness is not demonstrated

A generic risk such as Hallucinations does not yet describe the solution risk. A contextual scenario should identify the erroneous output or event, the information or action concerned, the affected party, the consequence, the point in the architecture where the risk materialises, and the means of detection and recovery.

The instruction to identify additional risks is useful, but there is no systematic completeness path covering intended purpose and consequences, service model and contract, architecture and data flows, permissions and datasets, retrieval and tools, automation and human oversight, and customer or business process impacts. Without this path, completeness depends too heavily on individual reviewer experience and library coverage.

1.6 Control implementation and control effectiveness are not separated

The guidance allows mitigation status to be recorded, including an in-progress state, before residual risk is assessed. It does not establish a mandatory evidence rule for reducing the score. Policy compliance evidence is mentioned elsewhere, but its relationship to risk mitigation and residual scoring is not sufficiently explicit.

The method should distinguish a proposed control, an implemented control, a tested control and a control with demonstrated operating effectiveness. Each material control needs an owner, evidence, an assessment date and a defined reassessment trigger. Residual risk should not be reduced solely because a mitigation has been selected or planned.

1.7 Overall solution risk and risk posture are not integrated

The materials use AI Act risk classification, business importance, model and dataset risk levels, individual inherent and marginal risk, residual risk and overall risk posture. Their relationships and decision rules are not explained adequately.

It remains unclear whether the highest individual residual risk determines overall acceptability, how clusters of related medium risks are considered, how dependencies and common failure modes are assessed, and whether an acceptable posture can be recorded while controls remain planned. The respective roles of regulatory classification, operational solution risk and assurance status are particularly important to separate.

Decision principle

A low AI Act classification can coexist with material operational risk or incomplete control evidence. Regulatory classification, residual solution risk and assurance status should be recorded as distinct concepts.

1.8 The checklist does not fully align with the intended method

The checklist strengthens the expectation that risks appear after model selection. Its model source choices are limited to Third-party, Open source and In-house, which do not identify the service and operating profile. It also instructs the user to delete inapplicable or duplicate risks without requiring an applicability rationale or retained lineage.

The checklist contains useful data, privacy, security, human oversight and Board decision fields. However, these fields do not yet form a mandatory architecture and evidence narrative that connects service selection, solution-specific risks, control operation and final acceptance.

2. Recommended Changes

The first three changes are essential. They should be resolved before the process is treated as a coherent approval method. The supporting changes then translate the method into practical workflows, lifecycle deliverables and checklist updates.

2.1 Essential change 1: Unify decision rights and risk acceptance

Create a single decision rights and risk acceptance matrix that is referenced consistently by the process, guideline and checklist. Each lifecycle gate should identify:

- the decision and its scope
- the person or body that prepares and presents the decision
- the accountable decision maker, with exactly one clearly identified A role
- mandatory specialist reviews, including legal, privacy, security, procurement, architecture and customer review where applicable
- the residual risk acceptance owner and the escalation threshold
- required evidence, decision conditions, validity period and reassessment triggers.

If the AI Board makes a binding deployment decision, its accountability for that decision must be recorded. If the AI System Owner makes the decision and the Board only reviews or recommends, the documentation must remove language that assigns final approval to the Board. Legal or compliance validation should remain distinct from acceptance of the complete business and operational risk.

Define which risks the AI System Owner may accept, when business or customer acceptance is required, when AI Board approval is mandatory and which risks cannot be accepted. Correct the treatment of Unacceptable risk so that approval cannot bypass the organisation's own acceptance boundary.

2.2 Essential change 2: Bind risk inheritance to the actual service profile

Require every model and product component to have an assessment profile that identifies its origin, exact product and service tier, operating model, version, configuration and contractual basis. Consumer service, enterprise contracted service, self-hosted or in-house operation and hybrid arrangements should be distinguished without treating them as three completely separate base model libraries.

The assessment should reuse common base model risks where appropriate, then add or modify service and operating model risks and finally add solution-specific risks. Enterprise terms may change data handling, retention, subprocessors, support and change management risks. Self-hosted operation may reduce some external service risks while increasing internal infrastructure, maintenance, security and assurance responsibilities.

Required inheritance chain

Linked component risk candidate → service and contract verification → contextual applicability → solution-specific scenario → architecture and process controls → owner and evidence → residual risk → authorised acceptance.

Contractual evidence and technical configuration evidence should both be required. A contractual restriction does not by itself eliminate a technical event, and an enterprise agreement does not by itself establish the correctness or safety of model outputs.

2.3 Essential change 3: Require evidence and define overall risk decisions

Introduce an explicit control state model: proposed, implemented, tested and operating effectively. Material controls should have an owner and dated evidence. A residual risk reduction must be traceable to the controls and evidence that justify it, not only to a selected mitigation record.

Define how individual residual risks contribute to the overall solution decision. At minimum, the method should address the highest residual risk, clusters of related risks, common causes, control dependencies, unacceptable

scenarios and incomplete evidence. Overall risk posture should not be calculated solely from the number of risks marked acceptable.

Record three separate decision views:

- regulatory classification, including AI Act scope and role
- inherent and residual operational solution risk
- assurance status, including ownership, implementation, testing and evidence completeness.

The approval record should identify the assessed system and component versions, accepted residual risks, decision maker, conditions, exceptions, validity period and events that require reassessment.

2.4 Supporting change: Adopt a solution risk workflow

Use one common workflow for inherited, recommended and custom risks:

- Confirm intended purpose, output role, affected parties, consequences and permission to process data.
- Confirm the solution architecture, service model, data flows, identities, permissions, tools, actions and human decision points.
- Review each inherited risk for applicability and record the rationale for exclusion where relevant.
- Write a solution-specific scenario describing the event, cause, affected party, consequence, architectural location and detectability.
- Consolidate duplicate scenarios while preserving links to all original library and component risks.
- Identify additional risks created by the complete solution, including those not present in any component library.
- Assign controls to the correct provider, shared platform, solution owner and business owner responsibilities.
- Attach evidence, assess residual risk and obtain acceptance from the authorised owner.

2.5 Supporting change: Strengthen lifecycle gate deliverables

Gate	Minimum required input	Decision focus
Qualification and registration	Purpose, affected parties, consequences, initial solution risk, regulatory classification, exact product and service profile, contract basis and ownership.	Whether the proposed use is permitted and proportionate to proceed.
Design and development	Architecture, data flows, permissions, tools, solution risk scenarios, responsibility allocation and planned controls.	Whether the design can meet the required controls and evidence.
Verification and validation	Test results, control effectiveness evidence, unresolved limitations, residual risks and legal or compliance validation.	Whether the evidence supports the proposed residual risk and readiness.
Deployment	Approved versions, release scope, acceptance records, conditions, monitoring, incident handling and reassessment triggers.	Whether the accountable authority permits release.
Operation and re-evaluation	Monitoring, incidents, overrides, drift, vendor or model changes, contract changes and periodic evidence refresh.	Whether operation remains within the approved risk envelope.
Retirement	Data deletion, access removal, contract termination, records retention and residual dependencies.	Whether retirement is complete and traceable.

2.6 Supporting change: Align the checklist and implementation guidance

Expand the model section of the checklist to include model origin, service and operating model, exact product and tier, version, configuration, contractual basis and responsibility split. Replace the expectation that model selection alone produces the risk assessment with a requirement to review risks from models, products, agents, datasets, context and the solution architecture.

Replace the simple deletion of inapplicable or duplicate risks with documented applicability decisions and controlled consolidation. Preserve the rationale and source lineage. Require custom risks where the complete solution introduces scenarios that are absent from inherited content.

Clarify the Board decision section so that it mirrors the decision rights matrix. The recorded outcome should distinguish approval of the system, acceptance of residual risk, conditions and required specialist validation.

2.7 Implementation priority and expected outcome

Priority	Actions
Immediate	Resolve AI Board accountability, define risk acceptance and escalation thresholds, correct the treatment of Unacceptable risk, and prohibit residual risk reduction based only on planned controls.
Next documentation release	Introduce service and operating profiles, the common solution risk workflow, evidence requirements, overall risk decision rules and minimum gate deliverables.
Following improvement	Improve deduplication and lineage, reuse shared controls with solution-level validation, and align monitoring metrics with accepted risk and evidence rather than registration volume alone.

The expected result is a governance process in which the tool supports the assessment rather than becoming the assessment itself. The library supplies candidate knowledge, the service and contractual profile establishes the correct context, the architecture explains how risks materialise, evidence demonstrates control operation, and an accountable authority decides whether the residual risk is acceptable.

Target state

A complete decision should be traceable from intended use and consequences to service selection, architecture, solution risks, controls, evidence, residual risk and authorised acceptance. Without that chain, a low classification or completed review task is not sufficient evidence of a governed solution.

Reviewed Documents / Sources:

